



Weekly IT Security Brief (Official-source-first) | 2026-07-05 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 2 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-45659(2026-07-04), CVE-2026-48558(2026-07-02). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Improving security posture across the Microsoft partner ecosystem. Read how Microsoft strengthens partner ecosystem security with CSP vetting, least privilege access, monitoring, and risk management best practices. The post Improving security...
- Threat trend #2: Microsoft named a leader in the Frost Radar for cloud and application runtime security. Frost & Sullivan names Microsoft a leader as cloud and application security converge into unified, runtime risk reduction. The post Microsoft named a lead...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-45659

CVE Title	CVE-2026-45659 microsoft/sharepoint_server Deserialization
CVE Description	Deserialization of untrusted data in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/sharepoint_server
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-04
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-45659

CVE-2026-48558

CVE Title	CVE-2026-48558 simple-help/simplehelp Auth Bypass
CVE Description	SimpleHelp versions 5.5.15 and prior and 6.0 pre-release versions contain an authentication bypass vulnerability in the OIDC authentication flow. When OIDC authentication is configured, identity tokens submitted during login are accepted without verifying their cryptographic signature. In a vulnerable configuration, a remote, unauthenticated attacker can submit a forged token containing arbitrary identity claims to...
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	simple-help/simplehelp
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-02
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-48558



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-10643

CVE Title	CVE-2026-10643 待核實 Out-of-Bounds
CVE Description	Zephyr's IP socket recvmsg() implementation (subsys/net/lib/sockets/sockets_inet.c, insert_pktinfo()) validated the user-supplied ancillary (msg_control) buffer using only the payload length (msg-msg_controllen < pktinfo_len) before writing a full control message consisting of an aligned cmsg header plus the payload. Because the check omitted the cmsg header size, a control buffer whose length falls in the u...
Affected Products	待核實
Risk Score	8.7 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10643

CVE-2026-8095

CVE Title	CVE-2026-8095 待核實 Unknown Type
CVE Description	The Frontend File Manager Plugin plugin for WordPress is vulnerable to Authenticated Arbitrary File Deletion in versions up to and including 23.6. This is due to a case-sensitive bypass of the wpfm_dir_path parameter sanitization in the wpfm_file_meta_update AJAX handler, where supplying WPFM_DIR_PATH in uppercase evades the unset check and is normalized to wpfm_dir_path by sanitize_key() during update_post_meta(),...
Affected Products	待核實
Risk Score	8.1 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8095

CVE-2026-58049

CVE Title	CVE-2026-58049 待核實 Out-of-Bounds
CVE Description	FFmpeg's RASC video decoder (decode_dlt in libavcodec/rasc.c) performs 32-bit reads and writes at the row cursor before the NEXT_LINE row-boundary check and validates the DLTA region in pixel rather than byte units, so a DLTA run on a PAL8 frame can access several bytes past the row allocation. A crafted media stream using the RASC FourCC, decoded by libavcodec, triggers a bitstream-controlled out-of-bounds he...
Affected Products	待核實
Risk Score	8.6 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-58049

CVE-2026-58050

CVE Title	CVE-2026-58050 libssh2/libssh2 Buffer Overflow
CVE Description	libssh2 through 1.11.1 reads an attacker-controlled 32-bit attribute count from a publickey-subsystem response and uses it in the allocation <code>num_attrs * sizeof(libssh2_publickey_attribute)</code> without bounds checking, so on 32-bit platforms the multiplication overflows to an undersized buffer. A malicious SSH server can then drive the attribute-parsing loop to write past the allocation, causing a heap buffer overflow in...
Affected Products	libssh2/libssh2
Risk Score	7.0 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-58050



Report B: Threat Intelligence News (last 7 days)

Headline: Improving security posture across the Microsoft partner ecosystem

Source	Microsoft Security Blog
Published	Thu, 02 Jul 2026 16:00:00 +0000
Key Takeaway	Read how Microsoft strengthens partner ecosystem security with CSP vetting, least privilege access, monitoring, and risk management best practices. The post Improving security posture across the Microsoft partner ecosystem appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/02/improving-security-posture-across-the-microsoft-partner-ecosystem/

Headline: Microsoft named a leader in the Frost Radar for cloud and application runtime security	
Source	Microsoft Security Blog
Published	Wed, 01 Jul 2026 16:00:00 +0000
Key Takeaway	Frost & Sullivan names Microsoft a leader as cloud and application security converge into unified, runtime risk reduction. The post Microsoft named a leader in the Frost Radar for cloud and application runtime security appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/01/microsoft-named-a-leader-in-the-frost-radar-for-cloud-and-application-runtime-security/

Headline: CISA Announces New Advisory Council to Strengthen Partnerships and Secure Critical Infrastructure

Source	CISA News
Published	Wed, 01 Jul 26 12:00:00 +0000
Key Takeaway	CISA Announces New Advisory Council to Strengthen Partnerships and Secure Critical Infrastructure Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-announces-new-advisory-council-strengthen-partnerships-and-secure-critical-infrastructure

Headline: New CISA Guide Assists Federal Agencies with Transitioning to Modernized Zero Trust Architectures

Source	CISA News
Published	Wed, 24 Jun 26 12:00:00 +0000
Key Takeaway	New CISA Guide Assists Federal Agencies with Transitioning to Modernized Zero Trust Architectures Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/new-cisa-guide-assists-federal-agencies-transitioning-modernized-zero-trust-architectures

Headline: Catan and Mouse

Source	Cisco Talos Blog
Published	Thu, 02 Jul 2026 18:00:34 GMT
Key Takeaway	Adaptation. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ios/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/catan-and-mouse/

Headline: Martin Lee: Running through the Arctic (and the threat landscape)

Source Cisco Talos Blog

Published Wed, 01 Jul 2026 10:00:57 GMT

Key Takeaway Ever wonder how someone goes from studying human viruses to leading cybersecurity teams? In this Humans of Talos, we're joined by Martin Lee, EMEA Lead, to talk about his journey into the industry.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/martin-lee-running-through-the-arctic-and-the-threat-landscape/>

Headline: U.S. Government Entity Paid Kairos \$1 Million in Data-Theft Extortion Case

Source	The Hacker News
Published	Sat, 04 Jul 2026 18:17:53 +0530
Key Takeaway	The odd part: the group that took the money calls itself Kairos, but it may not be a ransomware gang at all. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/07/us-government-entity-paid-kairos-group.html

Headline: North Korean Hackers Publish 108 Malicious Packages and Extensions in PolinRider Campaign

Source	The Hacker News
Published	Sat, 04 Jul 2026 16:47:24 +0530
Key Takeaway	The North Korean threat actors linked to the Contagious Interview campaign have been observed publishing 108 unique packages and web browser extensions spanning npm, Packagist, Go, and Google Chrome as part of an ongoing activity referred to as PolinRider. "The campaign remains active, and new malic Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/latera...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/07/north-korean-hackers-publish-108.html

Headline: In Other News: Canadian Hacker Jailed, Open Source Zero-Days, Two Sentenced for ATM Jackpotting

Source	SecurityWeek
Published	Fri, 03 Jul 2026 15:10:42 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: Anonymous-linked Canadian hacker jailed, researcher drops zero-days in open source projects, Venezuelans sentenced in the US over ATM jackpotting. The post In Other News: Canadian Hacker Jailed, Open Source Zero-Days, Two Sentenced for ATM Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral move...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-canadian-hacker-jailed-open-source-zero-days-two-sentenced-for-atm-jackpotting/

Headline: Agentic AI Used to Conduct Ransomware Attack via Langflow

Source	SecurityWeek
Published	Fri, 03 Jul 2026 11:00:00 +0000
Key Takeaway	Attack demonstrates how LLM agents can combine known exploitation techniques with real-time reasoning to automate complex, multi-stage intrusions. The post Agentic AI Used to Conduct Ransomware Attack via Langflow appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/agentic-ai-used-to-conduct-ransomware-attack-via-langflow/

Headline: JadePuffer ransomware used AI agent to automate entire attack

Source	BleepingComputer
Published	Sat, 04 Jul 2026 10:16:38 -0400
Key Takeaway	Researchers identified what they believe is the first documented case of a ransomware operation, JadePuffer, conducted entirely by a large language model (LLM) agent. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/jadepuffer-ransomware-used-ai-agent-to-automate-entire-attack/

Headline: NetNut proxy network disrupted, 2 million infected devices cut off

Source BleepingComputer

Published Fri, 03 Jul 2026 13:50:04 -0400

Key Takeaway A joint operation involving Google has disrupted NetNut, a residential proxy network that gave access to millions of compromised Android devices, including smart TVs and streaming boxes. [...]
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/netnut-proxy-network-disrupted-2-million-infected-devices-cut-off/>



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)